

Part 1 : Advanced Threat Analysis

Advanced Threat Analysis is the process of proactively identifying, modeling, and understanding how adversaries can attack a system. It combines structured methodologies like STRIDE, industry-standard knowledge bases like MITRE ATT&CK, and real-world attack case studies to prepare defenders.

1.1 MITRE ATT&CK Framework

What is MITRE ATT&CK?

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a globally accessible knowledge base of adversary tactics and techniques based on real-world observations. It is used by security teams worldwide to understand how attackers operate and build defenses against them.

Key Tactics & Techniques Studied

Technique ID	Technique Name	Tactic	Description	Defense
T1566	Phishing	Initial Access	Attackers send malicious emails with links or attachments to gain initial access into a target network.	Email filtering, user awareness training, MFA
T1059	Command & Scripting Interpreter	Execution	Attackers use PowerShell, Bash, Python etc. to execute malicious commands on compromised systems.	Script block logging, AppLocker, EDR monitoring
T1190	Exploit Public-Facing Application	Initial Access	Attackers exploit vulnerabilities in internet-facing apps (web servers, VPNs, APIs) to gain access.	Patch management, WAF, vulnerability scanning
T1071	Application	Command	Attackers use HTTP,	Deep packet

Technique ID	Technique Name	Tactic	Description	Defense
	Layer Protocol	& Control	HTTPS, DNS to communicate with compromised machines to avoid detection.	inspection, DNS monitoring, proxy filtering

What it is:

- Phishing is the most common initial access technique used by threat actors worldwide.
- Attackers send fraudulent emails that appear to come from trusted sources (banks, IT departments, colleagues).
- These emails contain malicious attachments (Office macros, PDFs) or links to credential-harvesting websites.
- Sub-techniques include: T1566.001 (Spearphishing Attachment), T1566.002 (Spearphishing Link), T1566.003 (Spearphishing via Service).

How attackers use it:

- Step 1: Attacker researches the target (LinkedIn, company website) to craft convincing emails.
- Step 2: Sends email with subject like 'Urgent: Invoice attached' or 'Password expiry notice'.
- Step 3: Victim opens attachment → macro executes → malware downloads → attacker gets foothold.
- Step 4: Attacker moves laterally from the compromised system.

Defenses:

- Email gateway filtering (block malicious attachments and suspicious domains).
- Multi-Factor Authentication (MFA) — even if credentials stolen, attacker cannot log in.
- Security awareness training — educate users to spot phishing indicators.
- Disable Office macros by default via Group Policy.
- Deploy DMARC, DKIM, SPF email authentication protocols.

1.2 STRIDE Threat Model

What is STRIDE?

STRIDE is a threat modeling framework developed by Microsoft to systematically identify security threats in a system. Each letter represents a threat category that security teams map to components of their architecture.

Letter	Threat	Violates	Example
S	Spoofing	Authentication	Attacker impersonates a legitimate user by stealing session cookies.
T	Tampering	Integrity	Attacker modifies data in transit (e.g., SQL Injection to change database records).
R	Repudiation	Non-repudiation	User denies performing an action because audit logs are missing or disabled.
I	Information Disclosure	Confidentiality	Sensitive data exposed via unencrypted HTTP, verbose error messages, or broken access control.
D	Denial of Service	Availability	Attacker floods web server with requests, making it unavailable to legitimate users.
E	Elevation of Privilege	Authorization	Attacker gains admin access by exploiting a misconfigured sudo rule or unpatched kernel.

STRIDE Applied to: User → Web Application → Database

Threat Model Scope: A standard 3-tier web application with User, Web Server, and Database components.

Component / Flow	STRIDE Threat	Specific Attack	Mitigation
User → Web App (Login)	Spoofing	Attacker steals session token and impersonates authenticated user.	Implement secure session management, HTTPS, MFA, HttpOnly cookies.
User → Web App (Forms)	Tampering	Attacker injects malicious SQL via login form to bypass authentication.	Input validation, parameterized queries, WAF.
Web App → Database	Tampering	SQL Injection — attacker manipulates queries to extract, modify or delete database records.	Use prepared statements, ORM frameworks, least-privilege DB accounts.
Web App (Logs)	Repudiation	Attacker deletes log files after attack to remove evidence of intrusion.	Centralized log storage (SIEM), tamper-evident logging, write-once storage.
Web App → User	Information Disclosure	Error messages reveal database structure, stack traces, or	Disable verbose errors in production, implement custom error pages.

Component / Flow	STRIDE Threat	Specific Attack	Mitigation
		internal file paths.	
Web App Server	Denial of Service	Attacker sends thousands of requests per second, exhausting server resources.	Rate limiting, CDN with DDoS protection, load balancers.
Web App (Privileges)	Elevation of Privilege	Low-privilege user exploits broken access control to access admin panel.	Role-based access control (RBAC), principle of least privilege, access reviews.

STRIDE Threat Model

The STRIDE threat model was applied to a 3-tier web application consisting of User, Web Application, and Database components. Spoofing threats target the User-to-Application boundary through session hijacking and impersonation attacks, mitigated by MFA and HTTPS. Tampering threats affect both input forms (SQL injection) and the database layer, requiring parameterized queries and input validation. Repudiation risks arise from insufficient logging, countered by centralized SIEM integration. Information Disclosure can occur via verbose error messages, requiring custom error handling. Denial of Service attacks threaten availability, mitigated by rate limiting and CDN protection. Finally, Elevation of Privilege is countered through strict RBAC enforcement.

1.3 SolarWinds Supply Chain Attack — Case Study

The SolarWinds Orion attack (2020) is one of the most sophisticated supply chain attacks in history, attributed to the Russian state-sponsored group APT29 (Cozy

Bear). It affected over 18,000 organizations including US government agencies, Fortune 500 companies, and cybersecurity firms.

#	Category	Details
1	How Attackers Got In	Attackers compromised SolarWinds' build pipeline (CI/CD system) in late 2019. They injected the SUNBURST backdoor malware into legitimate Orion software updates (version 2019.4–2020.2.1). When customers updated the software, they unknowingly installed the backdoor.
2	What They Did	SUNBURST established a stealthy C2 (Command and Control) channel over HTTPS to attacker-controlled domains. Attackers moved laterally inside victim networks, stole credentials, exfiltrated sensitive data, and installed secondary backdoors (TEARDROP, RAINDROP) to maintain persistent access.
3	How Long Undetected	The initial compromise happened in October 2019. It was only discovered in December 2020 by FireEye (now Mandiant) — over 14 months of undetected activity. The malware used legitimate-looking traffic patterns and dormancy periods to evade detection.
4	Impact	Confirmed victims include US Treasury, Dept. of Homeland Security, Dept. of Justice, Microsoft, Intel, Cisco, and 18,000+ organizations that downloaded the compromised update. Terabytes of sensitive data were potentially exfiltrated.
5	Key Lessons Learned	1) Software supply chains are critical attack surfaces requiring integrity verification. 2) Code signing and build pipeline security must be audited regularly. 3) Even trusted software updates must be monitored. 4) Network segmentation limits blast radius. 5) Threat hunting and behavioral analytics can detect sophisticated attacks.